

# Week 4 Project Deliverable

## PaySphere Statement of Applicability (Partial) and Control Gap Assessment

**Project Type:** ISO/IEC 27001:2022 ISMS Governance and Control Assessment

**Organization:** PaySphere

**Deliverable:** Partial Statement of Applicability (SoA) and Gap Assessment

**Assessment Scope:** Selected Annex A Controls

**Assessment Period:** Week 4 of GRC Analyst Self-Curated Curriculum

---

### 1. Executive Summary

This project involved developing a partial **Statement of Applicability (SoA)** and conducting a control gap assessment for PaySphere's Information Security Management System (ISMS).

The objective was to evaluate selected ISO/IEC 27001:2022 Annex A controls against PaySphere's established ISMS scope, interested-party requirements, and previously identified information security risks.

Six controls were selected across multiple Annex A themes. Each control was assessed to determine:

- Whether the control is applicable to PaySphere's ISMS
- The business, regulatory, stakeholder, or risk-based justification for applicability
- The current implementation status
- The specific control gap where the control is not fully implemented

The assessment identified significant gaps in privileged access management, security awareness, security logging, and secure software development practices. One physical security control was assessed as **Not Applicable** due to PaySphere's cloud-native and fully remote operating model.

A key outcome of the assessment was the identification of multiple remediation tracks under the logging control, demonstrating that a single ISO control may require different technical implementations and evidence streams across different systems.

---

### 2. ISMS Scope Considered for the Assessment

The following ISMS scope was used as the basis for determining control applicability:

The Information Security Management System (ISMS) covers the design, development, and operation of PaySphere's payment processing platform, including PaySphere's AWS Mumbai infrastructure, DevOps function, and customer support function — specifically where these interact with cardholder or transaction data.

Third-party services that PaySphere relies on, including AWS, Razorpay, and Twilio, are addressed within scope as dependencies under documented shared-responsibility boundaries, rather than as directly certified entities.

Systems and functions that do not process cardholder or transaction data, including marketing campaigns and marketing sites, are excluded from scope unless explicitly integrated with in-scope systems in the future.

This scope was particularly important when determining whether a control was applicable. Controls were evaluated based on their relevance to systems and activities involving cardholder or transaction data rather than being automatically applied to every PaySphere business function.

---

## 3. Assessment Methodology

The following approach was used to assess each selected Annex A control:

### Step 1: Determine Applicability

The control was assessed against:

- The defined ISMS scope
- PaySphere's operating model
- Relevant information security risks
- Interested-party requirements
- Regulatory and contractual expectations

### Step 2: Identify the Driver

Each applicable control was linked to one or more relevant drivers, including:

- Risks from the PaySphere Risk Register
- Employee access and separation-of-duties requirements
- Security expectations associated with payment processing
- Requirements relating to the protection of transaction and cardholder data

### Step 3: Determine Implementation Status

The following status categories were used:

| Status                 | Definition                                                                                               |
|------------------------|----------------------------------------------------------------------------------------------------------|
| <b>Implemented</b>     | Control requirements are established and operating effectively based on available assessment information |
| <b>In Progress</b>     | Control implementation has begun but is not yet fully operational                                        |
| <b>Planned</b>         | Control implementation is formally intended but work has not yet begun                                   |
| <b>Not Implemented</b> | The required control mechanism is currently absent                                                       |
| <b>Risk Accepted</b>   | The organization has formally accepted the residual risk rather than implementing the control            |
| <b>Not Applicable</b>  | The control does not apply to the defined ISMS scope or operating environment                            |

#### Step 4: Identify the Specific Gap

Where a control was not implemented, the assessment documented the actual deficiency rather than using a generic statement such as "control missing."

This approach supports traceability between:

**Risk → Applicable Control → Implementation Status → Control Gap → Future Remediation**

## 4. Partial Statement of Applicability and Gap Assessment

| Control ID | Control Name                                           | Applicable? | Justification                                                                                                                         | Implementation Status | Identified Gap                                                                                                         |
|------------|--------------------------------------------------------|-------------|---------------------------------------------------------------------------------------------------------------------------------------|-----------------------|------------------------------------------------------------------------------------------------------------------------|
| A.5.15     | Access Control                                         | Yes         | Relevant to PSR-001 and PaySphere's requirement to ensure access is granted and managed according to defined rules and business need. | Not Implemented       | No formal access control policy is currently in place defining how access is granted, reviewed, modified, and revoked. |
| A.6.3      | Information Security Awareness, Education and Training | Yes         | Employees require baseline security awareness to support the secure handling of PaySphere                                             | Not Implemented       | No formal or recurring information security awareness and training program has been established.                       |

| Control ID | Control Name                 | Applicable? | Justification                                                                                                                                                                                                      | Implementation Status | Identified Gap                                                                                                                                                                                           |
|------------|------------------------------|-------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| A.7.1      | Physical Security Perimeters | No          | systems and sensitive payment-related information. PaySphere operates with a cloud-native and fully remote model, with no physical premises within the defined ISMS scope requiring a physical security perimeter. | Not Applicable        | No gap identified because the control is not applicable to the defined ISMS scope.                                                                                                                       |
| A.8.2      | Privileged Access Rights     | Yes         | Treats PSR-001. Privileged database access creates elevated risk because administrative permissions can allow unrestricted changes or access to production data.                                                   | Not Implemented       | Three employees currently have standing administrative access to the production database by default, with no separate privileged access workflow or enhanced approval process.                           |
| A.8.15     | Logging                      | Yes         | Treats PSR-001 through database audit logging and PSR-007 through application and web-layer security logging. These represent separate technical monitoring requirements.                                          | Not Implemented       | Two separate logging gaps exist: database-layer audit logging is not established, and application/WAF logging for the merchant portal is also not established. Separate remediation tracks are required. |
| A.8.28     | Secure Coding                | Yes         | Treats PSR-007 — Web Application Security Vulnerabilities (Merchant Portal). Secure coding practices are necessary to                                                                                              | Not Implemented       | No documented secure coding principles are formally established or consistently applied throughout the software development lifecycle.                                                                   |

| Control ID | Control Name | Applicable? | Justification                                                     | Implementation Status | Identified Gap |
|------------|--------------|-------------|-------------------------------------------------------------------|-----------------------|----------------|
|            |              |             | reduce vulnerabilities introduced during application development. |                       |                |

---

## 5. Detailed Control Assessment

### 5.1 A.5.15 — Access Control

#### Applicability: Yes

Access control is applicable because PaySphere processes sensitive transaction and cardholder-related information and requires access to systems and information to be governed according to defined business and security requirements.

The control supports the management of access across in-scope systems and ensures that access is granted, modified, and revoked according to consistent rules.

#### Risk Driver

The control is relevant to the access management concerns identified in the PaySphere environment, including PSR-001.

#### Implementation Status

##### Not Implemented

#### Identified Gap

PaySphere does not currently have a formal access control policy establishing requirements for:

- Access provisioning
- Access modification
- Access revocation
- Role-based access assignment
- Access approval
- Periodic access review

The absence of a formal access control framework creates the risk of inconsistent access decisions across systems and teams.

---

## 5.2 A.6.3 — Information Security Awareness, Education and Training

### Applicability: Yes

Security awareness and training are applicable to PaySphere because employees interact with systems, information, customer data, and operational processes that may affect the confidentiality, integrity, and availability of payment services.

Employees require an appropriate level of security awareness to understand their responsibilities and recognize common security risks.

### Implementation Status

#### Not Implemented

#### Identified Gap

PaySphere does not currently have a formal information security awareness, education, and training program.

The identified gap includes the absence of a structured program for:

- Security awareness training
  - Role-relevant security education
  - Recurring or periodic training
  - Evidence of employee participation
  - Tracking and monitoring of training completion
- 

## 5.3 A.7.1 — Physical Security Perimeters

### Applicability: No

PaySphere operates using a cloud-native and fully remote operating model.

The defined ISMS scope does not include physical facilities where cardholder or transaction data is processed through PaySphere-managed on-premises infrastructure.

AWS infrastructure and other third-party services are treated as dependencies under documented shared-responsibility boundaries.

### Implementation Status

#### Not Applicable

#### Justification

No PaySphere-managed physical security perimeter exists within the defined ISMS scope that requires implementation of this control.

This determination demonstrates that controls should not automatically be marked applicable solely because they appear in Annex A. Applicability must be assessed against the organization's actual environment and ISMS boundary.

---

## **5.4 A.8.2 — Privileged Access Rights**

### **Applicability: Yes**

Privileged access rights are highly applicable because administrative access to production databases can allow users to:

- Access sensitive data
- Modify production information
- Change database configurations
- Perform actions with significant security and operational impact

### **Risk Driver**

#### **PSR-001**

The risk is directly driven by the fact that three employees currently possess standing administrative access to the production database.

### **Implementation Status**

#### **Not Implemented**

#### **Identified Gap**

Three employees currently have production database administrative access by default.

Privileged access is not treated as a separate access category requiring enhanced controls.

No dedicated privileged access workflow currently exists for activities such as:

- Elevated access approval
- Time-bound privileged access
- Just-in-time access elevation
- Additional monitoring of privileged actions
- Enhanced review of administrative access

This creates a significant privileged access management gap because administrative access has not been sufficiently separated from normal user access.

---

## 5.5 A.8.15 — Logging

### **Applicability: Yes**

Logging is applicable because PaySphere requires monitoring and auditability across different technical layers.

The assessment identified two distinct risk-driven logging requirements.

### **Risk Driver 1: PSR-001**

Database audit logging is required to provide visibility into privileged activity.

Relevant evidence could include records of:

- Administrative database access
- Privileged queries
- Changes to sensitive records
- Configuration changes
- Other privileged actions performed within the production database

### **Risk Driver 2: PSR-007 — Web Application Security Vulnerabilities (Merchant Portal)**

Application and web-layer logging is required to support the detection and investigation of potentially malicious activity against the merchant portal.

Relevant evidence may include:

- Web application requests
- Authentication activity
- Suspicious HTTP requests
- WAF events
- Potential attack attempts against the application

### **Implementation Status**

#### **Not Implemented**

#### **Identified Gap**

The logging gap consists of two separate technical deficiencies:

#### **Gap 1: Database Audit Logging**

Appropriate database-layer audit logging is not established for privileged activity involving the production database.



## Gap 2: Application and WAF Logging

Appropriate application-layer and WAF logging is not established for monitoring security-relevant activity involving the merchant portal.

### Assessment Observation

Although both gaps fall under a single Annex A control, they represent separate technical implementations and potentially require different owners and remediation activities.

The remediation should therefore not be treated as a single generic task such as:

"Enable logging."

Instead, the organization should create separate remediation tracks for:

1. Database audit logging
2. Merchant portal/application/WAF security logging

This distinction improves accountability and reduces the risk that remediation of one logging layer is incorrectly considered remediation of the entire control.

---

## 5.6 A.8.28 — Secure Coding

### Applicability: Yes

Secure coding is applicable because PaySphere designs and develops its payment processing platform and merchant-facing applications.

Security weaknesses introduced during software development could directly affect the confidentiality, integrity, and availability of in-scope systems and data.

### Risk Driver

#### PSR-007 — Web Application Security Vulnerabilities (Merchant Portal)

Secure coding practices directly support the treatment of risks associated with vulnerabilities in the merchant-facing web application.

### Implementation Status

#### Not Implemented

#### Identified Gap

PaySphere does not currently have documented secure coding principles that are formally integrated into the software development lifecycle.

The organization lacks evidence of a consistent approach for:

- Defining secure coding expectations
- Applying security requirements during development
- Integrating secure development practices into the SDLC
- Demonstrating that developers consistently follow documented secure coding requirements

The absence of documented and consistently applied secure coding practices increases the likelihood that security vulnerabilities may be introduced into the merchant portal during development.

---

## 6. Control Applicability Summary

The assessment produced the following overall result:

### Assessment Outcome Number of Controls

|                 |   |
|-----------------|---|
| Applicable      | 5 |
| Not Applicable  | 1 |
| Implemented     | 0 |
| In Progress     | 0 |
| Planned         | 0 |
| Not Implemented | 5 |

The assessment identified that most selected controls have not yet been formally implemented within the assessed PaySphere environment.

This does not automatically mean that all security practices are absent across the organization. Rather, based on the information available for this assessment, sufficient evidence was not identified to demonstrate formal implementation of the selected controls.

---

## 7. Key Gaps Identified

The assessment identified the following priority gaps:

### 7.1 Privileged Access Management

Administrative access to the production database is currently provided as standing access to three employees.

**Key gap:** Privileged access is not governed through a separate privileged access management workflow.

---

## 7.2 Formal Access Governance

A formal access control policy has not been established.

**Key gap:** The organization lacks documented requirements governing how access is provisioned, modified, reviewed, and revoked.

---

## 7.3 Security Awareness and Training

A structured information security awareness and training program has not been established.

**Key gap:** Security awareness is not supported by a formal, recurring, and measurable training process.

---

## 7.4 Database Audit Logging

Production database activity does not have an identified audit logging mechanism sufficient to monitor privileged activity.

**Key gap:** Lack of database-layer audit logging for administrative and privileged actions.

---

## 7.5 Application and Web-Layer Logging

The merchant portal does not have an identified logging mechanism covering relevant application and WAF security events.

**Key gap:** Lack of dedicated application and web-layer security logging.

---

## 7.6 Secure Development Practices

Secure coding requirements are not formally documented or integrated into the software development lifecycle.

**Key gap:** Developers do not have a formally established and consistently applied secure coding framework.

---

## 8. Key Assessment Insights

### 8.1 Control Applicability Must Be Organization-Specific

A major outcome of the assessment was the determination that A.7.1, Physical Security Perimeters, is not applicable to the defined ISMS scope.

Rather than automatically applying every Annex A control, the assessment considered:

- PaySphere's remote operating model
- Its cloud-native infrastructure
- The defined ISMS boundary
- The absence of PaySphere-managed physical premises within scope

This demonstrates the importance of documenting clear, organization-specific justification when marking a control as not applicable.

---

### 8.2 General Access Control and Privileged Access Must Be Assessed Separately

The assessment distinguished between:

- General access governance under A.5.15
- Elevated administrative access under A.8.2

Although both controls relate to access management, the risks and gaps are different.

General access control focuses on whether access is governed according to defined rules and policies.

Privileged access management focuses specifically on elevated permissions that require additional restrictions and oversight.

This distinction prevented the same gap from being incorrectly assessed as two identical control failures.

---

### 8.3 One ISO Control Can Require Multiple Technical Evidence Streams

A.8.15 demonstrated that a single Annex A control may apply across multiple technical environments.

For PaySphere:

- Database audit logs support monitoring of privileged database activity associated with PSR-001.
- Application and WAF logs support monitoring of web application threats associated with PSR-007.

Although both fall under the same control, they require different evidence, potentially different technical owners, and separate remediation activities.

---

## 9. Recommended Next Steps

The identified gaps should be converted into a formal risk treatment and remediation plan.

Priority remediation activities should include:

### **1. Establish a Privileged Access Management Process**

Develop a dedicated workflow for administrative and privileged access, including appropriate approval and monitoring mechanisms.

### **2. Develop an Access Control Policy**

Document requirements governing access provisioning, modification, review, and revocation.

### **3. Establish a Security Awareness Program**

Develop recurring security awareness and training requirements and retain evidence of employee participation.

### **4. Implement Database Audit Logging**

Establish appropriate audit logging for privileged and administrative activity involving production databases.

### **5. Implement Merchant Portal and WAF Logging**

Establish logging and monitoring for security-relevant activity involving the merchant-facing application.

### **6. Establish Secure Coding Requirements**

Document secure coding principles and integrate them into PaySphere's software development lifecycle.

---

# 10. Conclusion

This project produced a partial Statement of Applicability and control gap assessment for PaySphere's Information Security Management System.

The assessment evaluated six ISO/IEC 27001:2022 Annex A controls across organizational, people, physical, and technological security themes.

The final assessment identified five applicable controls with implementation gaps and one control that was appropriately determined to be not applicable based on PaySphere's defined ISMS scope.

The most significant findings relate to:

- Privileged access management
- Formal access governance
- Security awareness and training
- Database audit logging
- Application and WAF logging
- Secure coding practices

A key strength of the assessment was maintaining traceability between the organization's risk register, ISMS scope, control applicability, identified gaps, and future remediation activities.

This deliverable demonstrates the practical GRC assessment process of translating an organization's scope and risks into an actionable ISO 27001 control applicability assessment and identifying specific implementation gaps that can subsequently be incorporated into a formal risk treatment plan.

---

## Portfolio Skills Demonstrated

Through this project, the following GRC and information security governance skills were applied:

- ISO/IEC 27001:2022 Annex A control interpretation
- Statement of Applicability development
- ISMS scope analysis
- Control applicability assessment
- Risk-to-control mapping
- Control gap identification
- Privileged access risk assessment
- Security logging assessment
- Secure SDLC governance assessment
- Evidence-oriented audit thinking
- Remediation planning and ownership considerations
- Identification and documentation of non-applicable controls

